



INCIDENT RESPONSE RUNBOOK

UnauthorizedAccess:S3/MaliciousIPCaller

Detecting and responding to unauthorized S3 access from malicious IP addresses, including Tor exit nodes, using Amazon GuardDuty and AWS CloudTrail.

Severity HIGH — CVSS-aligned

Finding Type UnauthorizedAccess:S3/MaliciousIPCaller

Primary Service Amazon GuardDuty

Author Geoffrey Muriuki Mwangi (Atlas-Ghostshell)

Version 1.0

Date May 25, 2026

Classification CONFIDENTIAL — Internal Use Only

TABLE OF CONTENTS

1	Incident Overview	
2	Detection	
3	Preserve	
4	Contain	
5	Investigate	
6	Remediate	
7	Recover	
8	Post-Incident Documentation	
9	Severity & Escalation Matrix	

SECTION 1 — INCIDENT OVERVIEW

This runbook governs the response to a GuardDuty finding of type **UnauthorizedAccess:S3/MaliciousIPCaller**. This finding fires when an IAM principal makes API calls to an S3 bucket from an IP address identified in AWS threat intelligence feeds as malicious — including known Tor exit nodes, command-and-control infrastructure, and botnet nodes.

This finding indicates that valid AWS credentials have been used from a threat actor controlled or anonymised network. Whether the API call succeeded or was denied, the credential exposure itself constitutes a confirmed incident requiring immediate response.

Finding Summary

Finding Type	UnauthorizedAccess:S3/MaliciousIPCaller
Severity	HIGH — Immediate response required
Data Source	CloudTrail management events, S3 data events
CVSS Alignment	AV:N / AC:L / PR:L / UI:N / S:U / C:H / I:H / A:N — Base Score: 8.1
Resource Type	S3 Bucket (primary target), IAM User/Role (access vector)
Trigger	API call to S3 from a known malicious IP address or Tor exit node
False Positive Rate	Low — Tor exit node IPs are unambiguously non-legitimate for AWS API access

Why This Finding Matters

An attacker routing AWS API calls through Tor or a known malicious IP is deliberately attempting to obscure their identity and origin. This behaviour pattern is consistent with credential theft followed by reconnaissance or data exfiltration. The use of Tor specifically indicates an actor aware of AWS monitoring and actively attempting to evade attribution.

Threat Actor Objectives — Likely Attack Chain

Initial Access	Credential theft via phishing, exposed access keys in public repositories, or credential stuffing
Discovery	S3 ListBuckets, ListObjects — enumerate accessible resources
Collection	S3 GetObject — download sensitive data
Exfiltration	Data transferred out via the same Tor-proxied API session
Persistence	Creation of secondary IAM credentials or backdoor roles for continued access

SECTION 2 — DETECTION

How This Incident Is Detected

GuardDuty continuously analyses CloudTrail management events and S3 data events, cross-referencing source IP addresses against AWS threat intelligence feeds. When a match is found, a finding is generated automatically — no manual log review required.

Alert Sources

Primary	Amazon GuardDuty — automatic finding generation
Secondary	CloudWatch Alarm — SNS email notification if metric filter configured for GuardDuty findings
Tertiary	AWS Security Hub — finding aggregated and scored within minutes of GuardDuty detection

Immediate Fields to Extract from the GuardDuty Finding

When the finding fires, immediately record the following fields before taking any action:

Finding ID	Unique identifier — used to reference this specific finding in all communications
Finding Type	Confirm: UnauthorizedAccess:S3/MaliciousIPCaller
Severity	Confirm HIGH or CRITICAL — determines escalation path
Timestamp	First seen and last seen — establishes the incident window
Account ID	Confirms which AWS account is affected
Region	Confirms which region the activity occurred in
Resource ID	The specific S3 bucket targeted
Principal ID	The IAM user or role whose credentials were used
Access Key ID	The specific access key used — primary pivot for investigation
Actor IP Address	The malicious IP — document for threat intelligence correlation
Actor ASN/Org	The network organisation — confirms Tor exit node or malicious infrastructure
Error Code	AccessDenied = access blocked. Blank = access succeeded. Critical distinction.

■ If Error Code is blank or shows success — treat as confirmed data exfiltration. Escalate immediately to Critical severity.

SECTION 3 — PRESERVE

Preservation must occur before any containment or remediation action. Remediating before preserving destroys evidence and makes root cause analysis, legal proceedings, and regulatory reporting impossible. This order is non-negotiable.

3.1 Preserve GuardDuty Finding

- 1 In GuardDuty → Findings → open the specific finding.
- 2 Click **Actions** → **Export findings** — download the raw JSON.
- 3 Store the JSON in a secure, access-controlled S3 bucket with Object Lock enabled.
- 4 Record the Finding ID, timestamp, and all fields listed in Section 2 in the IR ticket.

3.2 Preserve CloudTrail Logs

CloudTrail logs are your forensic ground truth. Verify their integrity before anything else.

- 1 Confirm CloudTrail is still active and delivering logs — check the trail status in the CloudTrail console.
- 2 Validate log file integrity using the AWS CLI:

```
aws cloudtrail validate-logs \ --trail-arn
arn:aws:cloudtrail:us-east-1:ACCOUNT_ID:trail/TRAIL_NAME \ --start-time
2026-01-01T00:00:00Z
```
- 3 If validation fails — log tampering may have occurred. Escalate to Critical immediately.
- 4 Export CloudTrail events for the incident window to a secure evidence bucket.

3.3 Preserve S3 Access Logs

- 1 Navigate to the affected S3 bucket → Properties → Server access logging.
- 2 If access logging is enabled, download the logs for the incident window immediately.
- 3 S3 access logs show every object-level operation — GetObject, PutObject, DeleteObject — with source IP.
- 4 If access logging was NOT enabled — document this as a control gap in the IR report.

3.4 Snapshot Affected EC2 Instances (if applicable)

If the compromised IAM principal is associated with an EC2 instance role, take an EBS snapshot before any remediation:

```
aws ec2 create-snapshot \ --volume-id vol-XXXXXXXXXXXXXXXX \ --description
'IR-Snapshot-INCIDENT_ID-$(date +%Y%m%d)'
```

SECTION 4 — CONTAIN

Containment stops the attacker's active access without destroying evidence. Execute these steps in order immediately after preservation is confirmed.

4.1 Disable the Compromised Access Key

Disabling deactivates the key immediately without deleting it — preserving it as evidence and allowing restoration if the key is confirmed legitimate.

```
aws iam update-access-key \ --access-key-id AKIAIOSFODNN7EXAMPLE \ --status Inactive \
--user-name AFFECTED_USERNAME
```

■ **Do NOT delete the key yet — deletion destroys forensic evidence.**

4.2 Revoke All Active IAM Sessions

Disabling the access key does not terminate active sessions already authenticated. Attach a deny-all policy to immediately revoke all existing sessions:

```
# Attach an explicit deny policy to the affected user aws iam put-user-policy \
--user-name AFFECTED_USERNAME \ --policy-name EmergencyDenyAll \ --policy-document
'{"Version":"2012-10-17","Statement":[{"Effect":"Deny","Action":"*","Resource":"*"}]}'
```

4.3 Enforce MFA on Root and All Admin IAM Users

- 1 Verify root account MFA is active — AWS Console → Account → MFA.
- 2 Audit all IAM users with AdministratorAccess — confirm MFA is enforced on each.
- 3 Temporarily disable console access for any admin user without MFA until it is configured.

4.4 Restrict the Affected S3 Bucket

Apply a bucket policy that explicitly denies all access except from known-good IAM principals during the incident window:

```
# Navigate to S3 → Affected Bucket → Permissions → Bucket Policy # Add explicit Deny for
all principals except your admin role ARN
{"Version":"2012-10-17","Statement":[{"Effect":"Deny","Principal":"*",
"Action":"s3:*","Resource":["arn:aws:s3::BUCKET_NAME",
"arn:aws:s3::BUCKET_NAME/*"],"Condition":{"ArnNotEquals":
{"aws:PrincipalArn":"arn:aws:iam::ACCOUNT_ID:role/AdminRole"}}}]}
```

4.5 Block the Malicious IP at the Network Layer

- 1 Add the malicious IP to AWS WAF IP block list if a WAF is deployed in front of the bucket.
- 2 Add the IP to a GuardDuty Threat Intelligence list for ongoing monitoring.
- 3 If using VPC endpoints for S3, update the VPC endpoint policy to deny the source IP.

SECTION 5 — INVESTIGATE

Investigation builds the complete attack timeline — from initial credential exposure to the full scope of actions taken. Use CloudTrail as the primary evidence source and CloudWatch Log Insights for efficient querying.

5.1 Query CloudTrail for All Actions by the Compromised Key

In CloudWatch Log Insights — select the CloudTrail log group and run:

```
fields @timestamp, eventName, sourceIPAddress, userIdentity.accessKeyId,  
requestParameters, responseElements.@message | filter userIdentity.accessKeyId =  
'AKIAIOSFODNN7EXAMPLE' | sort @timestamp asc | limit 500
```

This returns every API call made with the compromised key in chronological order — your complete attack timeline.

5.2 Identify What Was Accessed in S3

```
fields @timestamp, eventName, requestParameters.bucketName, requestParameters.key,  
sourceIPAddress, errorCode | filter eventSource = 's3.amazonaws.com' and  
userIdentity.accessKeyId = 'AKIAIOSFODNN7EXAMPLE' | sort @timestamp asc
```

Look for: ListObjects (reconnaissance), GetObject (data access), PutObject (data staging), DeleteObject (evidence destruction). Any GetObject with no errorCode = confirmed data access.

5.3 Check for Lateral Movement and Persistence

```
fields @timestamp, eventName, requestParameters, userIdentity.accessKeyId | filter  
userIdentity.accessKeyId = 'AKIAIOSFODNN7EXAMPLE' and eventSource = 'iam.amazonaws.com' |  
sort @timestamp asc
```

IAM API calls by the compromised key indicate attempted privilege escalation or backdoor creation. CreateAccessKey, CreateUser, AttachUserPolicy are critical findings.

5.4 Determine Initial Access Vector

- | | |
|---|---|
| 1 | Search GitHub, GitLab, and public paste sites for the compromised access key ID — may have been exposed in a public commit. |
| 2 | Check IAM credential report for last used date/time — compare against normal usage patterns. |
| 3 | Review CloudTrail for the CreateAccessKey event to identify when and by whom the key was created. |
| 4 | Check if the user has any active access keys beyond the compromised one — secondary keys indicate pre-planned persistence. |

5.5 Determine Blast Radius

Answer each of the following questions explicitly in the IR report:

- Which S3 buckets were accessed or enumerated?
- Were any objects downloaded — and if so, what data classification level?
- Were any objects modified or deleted?
- Did the attacker make any IAM changes — new users, keys, policies?
- Did the attacker access any other AWS services beyond S3?
- Was any EC2 instance metadata accessed via this credential?

- Is there any evidence of data being exfiltrated to an external destination?

SECTION 6 — REMEDIATE

Remediation permanently eliminates the threat and closes the attack vector. Only execute after investigation is complete and blast radius is fully understood.

6.1 Delete the Compromised Access Key

```
aws iam delete-access-key \ --access-key-id AKIAIOSFODNN7EXAMPLE \ --user-name
AFFECTED_USERNAME
```

6.2 Issue New Credentials to the Legitimate User

```
aws iam create-access-key --user-name AFFECTED_USERNAME # Deliver new credentials to the
legitimate user via a secure out-of-band channel # Never deliver credentials via email or
Slack
```

6.3 Remove the Emergency Deny Policy

```
aws iam delete-user-policy \ --user-name AFFECTED_USERNAME \ --policy-name
EmergencyDenyAll
```

6.4 Harden the Affected S3 Bucket

- 1 Enable S3 server access logging if it was not already active — this is a critical gap if it was missing.
- 2 Enable S3 Object Lock on buckets containing sensitive data — prevents deletion and modification.
- 3 Review and tighten the bucket policy — apply least-privilege access. Remove any wildcard principals.
- 4 Enable S3 Block Public Access at both bucket and account level if not already enforced.
- 5 Enable default encryption (SSE-KMS) on all buckets containing sensitive data.
- 6 Remove the emergency containment bucket policy applied in Section 4 and replace with the hardened least-privilege policy.

6.5 Harden IAM Posture

- 1 Enforce MFA for all IAM users — attach an IAM policy that denies all actions if MFA is not present.
- 2 Rotate access keys for all IAM users on a 90-day schedule — implement key rotation policy.
- 3 Remove any unused IAM users, roles, and access keys identified during investigation.
- 4 Enable IAM Access Analyzer — flags resources accessible from outside the account.
- 5 Review all IAM policies for wildcard actions (Action: *) and wildcard resources (Resource: *) — remediate each.

6.6 Add Malicious IP to GuardDuty Threat Intelligence

```
# Create a threat intelligence list in GuardDuty with the malicious IP # GuardDuty →
Lists → Threat intel sets → Create # Upload a file containing the malicious IP(s) — one
```

IP per line # Format: 198.51.100.0/32

SECTION 7 — RECOVER

Recovery restores normal operations safely and verifies that the threat has been completely eliminated before closing the incident.

- 1 Confirm the compromised access key is deleted — **aws iam list-access-keys --user-name AFFECTED_USERNAME** should show only the newly issued key.
- 2 Confirm the emergency deny policy has been removed and the user has correct least-privilege permissions.
- 3 Confirm the S3 bucket policy has been restored to the hardened least-privilege version.
- 4 Verify GuardDuty shows no new findings for the affected principal in the 24 hours following remediation.
- 5 Verify CloudTrail is still active, delivering logs, and log file validation passes.
- 6 Confirm the legitimate user can access only their intended resources with the new credentials.
- 7 Run a GuardDuty finding status update — mark the original finding as **Resolved** in Security Hub.
- 8 Run AWS Trusted Advisor and Security Hub compliance checks — confirm no new control failures introduced during the incident response.
- 9 Brief the affected user on credential security — never commit credentials to repositories, use IAM roles over access keys where possible, enable MFA.
- 10 Declare the incident closed in the IR ticketing system — attach all evidence and the completed IR report.

SECTION 8 — POST-INCIDENT DOCUMENTATION

Every incident must be fully documented regardless of severity or outcome. Undocumented incidents provide no organisational learning and have no regulatory value. Complete the IR report within 48 hours of incident closure.

Required IR Report Sections

Executive Summary	One paragraph. What happened, when, what was affected, and what was done. Written for non-technical leadership.
Incident Timeline	Chronological table: timestamp, event, source, actor. Every action from first GuardDuty alert to incident closure.
Root Cause Analysis	How did the attacker obtain the credentials? What control failed or was absent?
Blast Radius	Exact list of resources accessed, data potentially exfiltrated, and IAM changes made.
Actions Taken	Exact remediation steps executed — with timestamps and operator name for each step.
Control Gaps Identified	Every security control that was absent or misconfigured that enabled or worsened this incident.
Lessons Learned	What would have detected this faster? What would have prevented it entirely?
Recommendations	Prioritised list of control improvements with owner, timeline, and success criteria.

Metrics to Record

MTTD	Mean Time to Detect — time from first malicious API call to GuardDuty finding generation
MTTR	Mean Time to Respond — time from GuardDuty alert to access key disabled
MTTC	Mean Time to Contain — time from GuardDuty alert to full containment confirmed
MTTE	Mean Time to Eradicate — time from GuardDuty alert to all compromised credentials rotated

SECTION 9 — SEVERITY & ESCALATION MATRIX

Severity determines who is notified, within what timeframe, and what response posture is adopted. Assess severity at detection time and reassess after investigation if the blast radius changes the picture.

Severity	Condition	Response SLA	Notify	Posture
CRITICAL (9–10)	Root account compromise OR confirmed data exfiltration OR ransomware deployed	15 minutes	CISO, Legal, AWS Support Executive leadership	Full war room All hands response
HIGH (7–8.9)	Compromised IAM credentials OR malicious IP access attempt OR Tor exit node finding	30 minutes	Security lead Cloud security engineer	Immediate contain Investigate in parallel
MEDIUM (4–6.9)	Unusual API activity OR first-time region access OR anomalous behaviour	4 hours	On-call security engineer	Investigate first Contain if confirmed
LOW (1–3.9)	Informational findings OR low-confidence detections	24 hours	Security team review	Document and monitor No immediate action

Runbook Review Schedule

Review Frequency	After every real incident, and on a minimum 6-month scheduled review cycle
Owner	Cloud Security Engineer / SOC Lead
Version Control	All runbook versions stored in the security team's version-controlled repository
Last Reviewed	May 25, 2026

Geoffrey Muriuki Mwangi · github.com/Atlas-Ghostshell · AWS Cloud Security Roadmap 2026 · Week 8 Deliverable ·
CONFIDENTIAL